OpenVAS : Guide Complet de A à Z

Bienvenue dans ce tutoriel sur OpenVAS (Open Vulnerability Assessment System), l'outil de scan de vulnérabilités open source le plus utilisé dans le monde de la cybersécurité. Ce guide progressif vous accompagnera depuis les concepts fondamentaux jusqu'à la maîtrise essentielle de cet outil indispensable pour tout professionnel de la sécurité informatique.

Table des matières

OpenVAS : Guide Complet de A à Z 1
A. Qu'est-ce qu'OpenVAS et GVM ? 3
B. Architecture Technique de GVM 4
C. Prérequis et Préparation 5
1) Configuration Matérielle Recommandée 5
2) Environnements Supportés 6
3) Installation Détaillée sur Kali Linux 6
4) Configuration après l'installation 9
a) Synchronisation des flux 9
b) Vérification du service 9
c) Configuration utilisateur administrateur 9
D. Configuration Initiale et Premier Contact 10
1) Navigation dans l'Interface GSA 10
2) Gestion des Utilisateurs 11
E. Votre Premier Scan Pas à Pas 12
F. Comprendre et Interpréter les Résultats 13
1) Anatomie d'un Résultat de Vulnérabilité 14
G. Cas d'Usage Pratiques et Scans Avancés 16
H. Reporting, Légalité et Optimisation 18
1) Types de Rapports et Export 18

A. Qu'est-ce qu'OpenVAS et GVM ?

OpenVAS est un scanner de vulnérabilités open source puissant qui permet d'identifier les failles de sécurité dans vos systèmes, applications et infrastructures réseau. Depuis 2009, le projet a évolué pour devenir Greenbone Vulnerability Management (GVM), une suite complète d'outils de gestion des vulnérabilités. Il est important de comprendre que OpenVAS est désormais le moteur de scan au cœur de GVM, tandis que GVM représente l'architecture globale incluant l'interface web, la base de données et les services associés

OpenVAS

Moteur de scan historique, aujourd'hui intégré dans GVM. Effectue l'analyse technique des systèmes cibles.

GVM

Architecture complète incluant interface web, orchestration des scans, gestion des rapports et mise à jour des signatures.

Greenbone

Société allemande derrière le développement, proposant versions communautaire (gratuite) et commerciale (Greenbone Enterprise).

Les cas d'utilisation d'OpenVAS sont multiples et couvrent l'ensemble du spectre de la cybersécurité. Dans un contexte d'audit de sécurité, OpenVAS permet d'évaluer la posture de sécurité d'une organisation en identifiant les vulnérabilités exploitables. Les équipes de Security Operations Center (SOC) l'utilisent pour la surveillance continue et la détection proactive des failles. Pour les pentesters, il constitue un outil de reconnaissance essentiel en phase d'énumération. Enfin, dans un cadre de conformité réglementaire (ISO 27001, PCI-DSS, RGPD), OpenVAS aide à démontrer une gestion rigoureuse des vulnérabilités.

Avantages d'OpenVAS :

- Complètement gratuit et open source
- Base de vulnérabilités mise à jour quotidiennement (plus de 80 000 tests)
- Supporte l'authentification pour des scans approfondis
- Interface web moderne et intuitive Large communauté active
- Pas de limite de nombre de scans ou d'IP

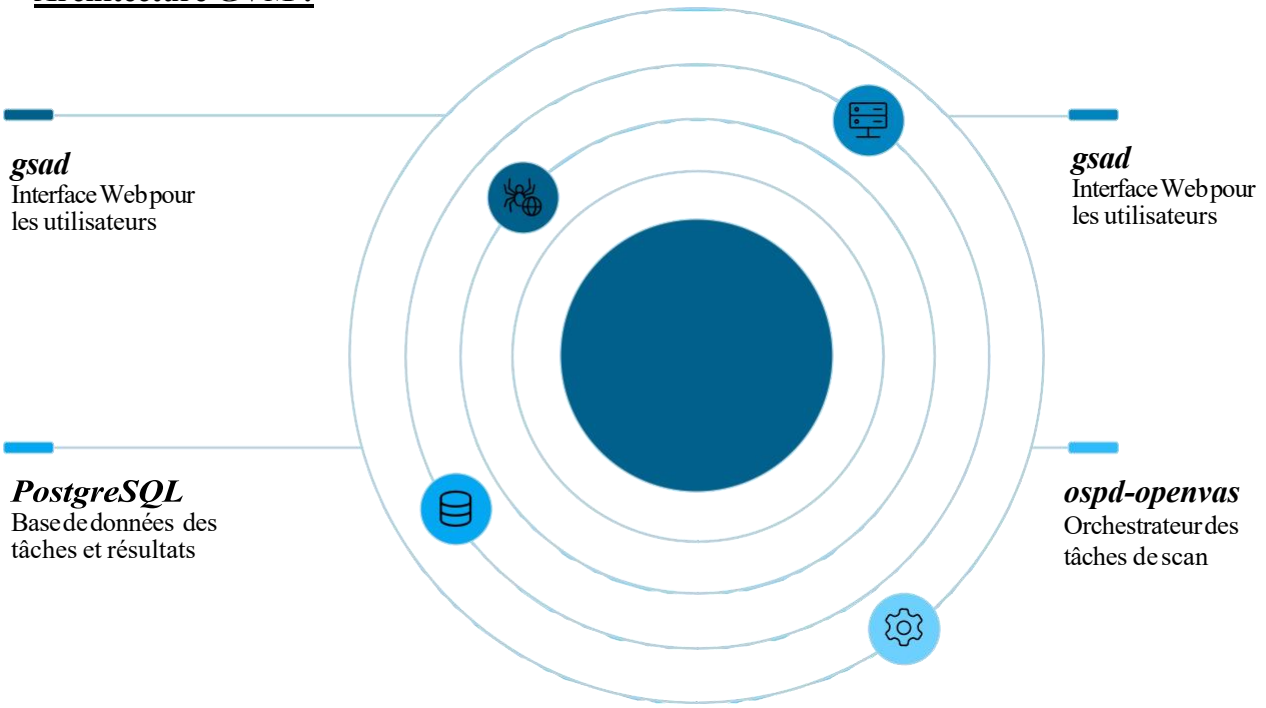
Limites à connaître :

- Performance inférieure aux solutions commerciales sur de très grands réseaux
- Configuration initiale plus complexe Documentation parfois fragmentée
- Support commercial limité à la version Greenbone Enterprise
- Taux de faux positifs parfois élevé nécessitant validation manuelle

B. Architecture Technique de GVM

Comprendre l'architecture interne de Greenbone Vulnerability Management est fondamental pour une utilisation efficace et un dépannage optimal. GVM repose sur une architecture modulaire où chaque composant joue un rôle spécifique dans le processus de scan et de gestion des vulnérabilités.

Architecture GVM :



Cette architecture en couches garantit la séparation des responsabilités et la scalabilité du système. Chaque composant peut être optimisé ou dépanné indépendamment.

GSAD - Greenbone Security Assistant Daemon

Interface web moderne accessible via navigateur (HTTPS port 9392). C'est votre point d'entrée principal pour créer des cibles, lancer des scans et consulter les rapports.

GVMD - Greenbone Vulnerability Manager Daemon

Cerveau du système, orchestrant toutes les opérations : planification des tâches, gestion des utilisateurs, stockage en base PostgreSQL, coordination avec ospd-openvas. Gère la logique métier complète de GVM.

OSPD-OpenVAS - Open Scanner Protocol Daemon

Couche d'abstraction entre gvmd et le scanner. Traduit les commandes de haut niveau en instructions de scan, gère les files d'attente et remonte les résultats à gvmd de manière standardisée.

OpenVAS Scanner

Moteur d'analyse proprement dit. Exécute les Network Vulnerability Tests (NVT) sur les cibles, interroge les services réseau, teste les exploits connus et collecte les informations détaillées sur les vulnérabilités détectées.

Feeds - Flux de Données

Bases de connaissances mises à jour quotidiennement : NVT (tests de vulnérabilités), SCAP (CVE, CPE, OVAL), CERT (alertes des CERT). Ces feeds sont téléchargés depuis les serveurs Greenbone et alimentent le scanner.

Fonctionnement d'un scan : Lorsque vous lancez un scan, GSAD envoie la requête à GVMD qui crée une tâche. GVMD demande à OSPD-OpenVAS de démarrer le scan. OSPD-OpenVAS configure le scanner OpenVAS avec les NVT appropriés. Le scanner effectue les tests sur la cible et remonte les résultats à OSPD-OpenVAS, qui les transmet à GVMD pour stockage en base. Vous consultez ensuite les résultats via GSAD.

C. Prérequis et Préparation

1) Configuration Matérielle Recommandée

OpenVAS peut fonctionner sur une machine modeste, mais les performances varient considérablement selon les ressources disponibles :

- Minimum : 2 CPU cores, 4 GB RAM, 20 GB stockage
- Recommandé : 4 CPU cores, 8 GB RAM, 50 GB SSD
- Production : 8+ CPU cores, 16 GB RAM, 100 GB SSD NVMe

La RAM est particulièrement critique car chaque scan peut consommer plusieurs centaines de Mo. Le stockage SSD accélère significativement l'accès aux feeds et à la base de données PostgreSQL

2) Environnements Supportés

- Kali Linux est l'environnement le plus simple car OpenVAS y est pré-empaqueté et optimisé. C'est le choix idéal pour débuter.
- Ubuntu/Debian nécessite plus de configuration manuelle mais offre plus de contrôle. Utilisez Ubuntu 22.04 LTS ou Debian 11+ pour une compatibilité optimale.
- D'autres distributions Linux sont supportées mais demandent une compilation depuis les sources, ce qui complexifie considérablement l'installation.

Prérequis Réseau

Connectivité réseau stable vers les cibles. Si vous scannez un réseau isolé, assurez-vous que votre machine OpenVAS peut y accéder. Pour les scans via Internet, vérifiez que votre bande passante est suffisante.

Sécurité du Scanner

OpenVAS doit être installé sur une machine dédiée et sécurisée. Appliquez les mises à jour système régulièrement. Isolez-le du réseau de production si possible. Utilisez un pare- feu pour limiter les accès entrants.

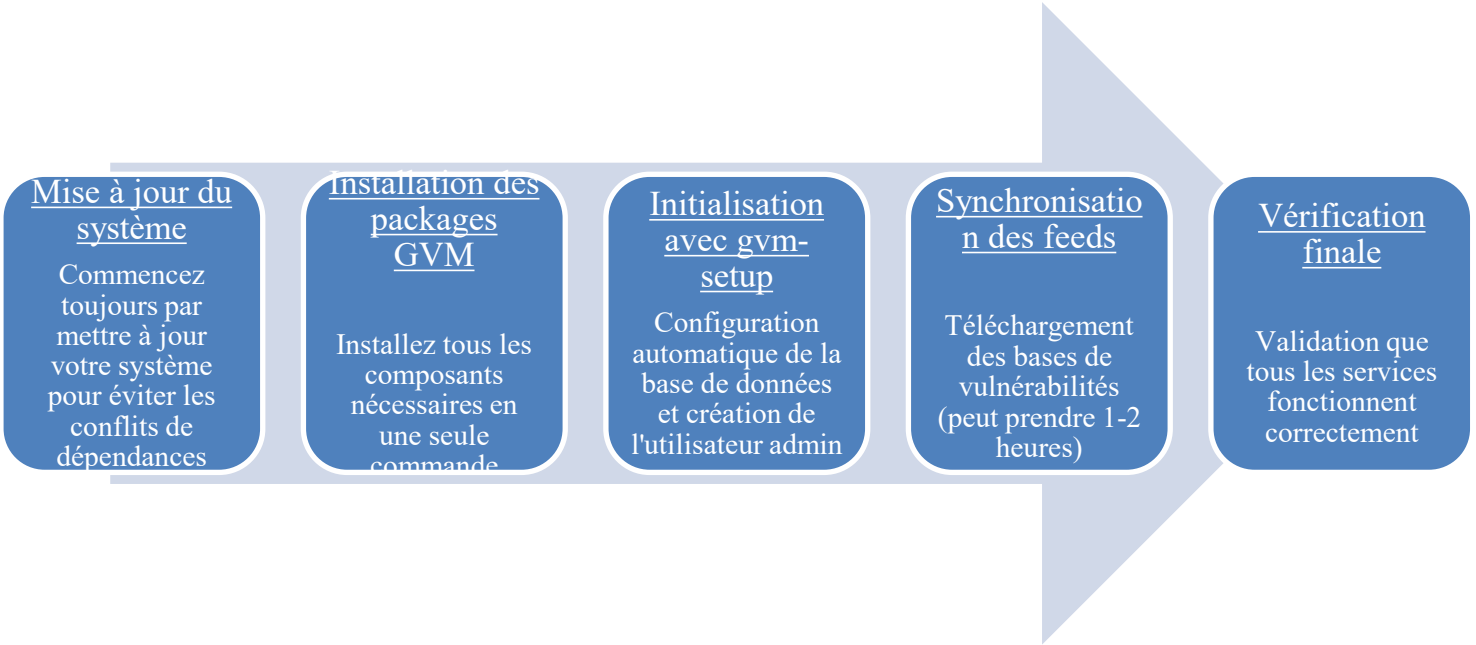
Cadre Légal

Ne scannez JAMAIS un système sans autorisation écrite explicite. Le scan de vulnérabilités peut être assimilé à une tentative d'intrusion. Obtenez toujours un accord formel avant tout test.

3) Installation Détaillée sur Kali Linux

Kali Linux est la distribution la plus adaptée pour débuter avec OpenVAS. L'installation y est grandement

simplifiée grâce aux packages officiels maintenus par l'équipe Kali. Suivez ces étapes méthodiquement pour une installation sans accroc.




```
# Étape 1 : Mise à jour du système
sudo apt update && sudo apt upgrade -y

# Étape 2 : Installation de GVM
sudo apt install gvm -y

# Étape 3 : Configuration initiale (durée : 15-30 min)
sudo gvm-setup

# Cette commande va :
# - Créer la base de données PostgreSQL
# - Générer les certificats SSL
# - Créer un utilisateur admin avec mot de passe aléatoire
# - Démarrer les services
# IMPORTANT : Notez le mot de passe admin affiché !

# Étape 4 : Synchronisation des feeds (durée : 1-2 heures)
sudo gvm-feed-update

# Cette commande télécharge :
# - NVT Feed : ~500 MB (Network Vulnerability Tests)
# - SCAP Feed : ~1 GB (CVE, CPE, OVAL)
# - CERT Feed : ~50 MB (alertes CERT)

# Étape 5 : Vérification de l'installation
sudo gvm-check-setup

# Cette commande vérifie :
# - Tous les services sont démarrés
# - Les feeds sont à jour
# - La base de données est accessible
# - Les permissions sont correctes
```

```
┌──(jean㉿lezelote)-[~]
└─$ sudo gvm-check-setup
gvm-check-setup 25.04.0
 This script is provided and maintained by Debian and Kali.
  Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner)...
        OK: OpenVAS Scanner is present in version 23.36.1.
        OK: Notus Scanner is present in version 22.7.2.
        OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
        OK: _gvm owns all files in /var/lib/openvas/gnupg
        OK: redis-server is present.
        OK: scanner (db_address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
        OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
        OK: _gvm owns all files in /var/lib/openvas/plugins
        OK: NVT collection in /var/lib/openvas/plugins contains 95078 NVTs.
        OK: The notus directory /var/lib/notus/products contains 512 NVTs.
Checking that the obsolete redis database has been removed
        OK: No old Redis DB
        OK: ospd-openvas service is active.
        OK: ospd-OpenVAS is present in version 22.10.0.
Step 2: Checking GVMD Manager ...
        OK: GVM Manager (gvmd) is present in version 26.13.0.
Step 3: Checking Certificates ...
        OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
        OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
        OK: SCAP data found in /var/lib/gvm/scap-data.
        OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking Postgresql DB and user ...
        OK: Postgresql version and default port are OK.
 gvmd      | _gvm         | UTF8     | libc                  | fr_FR.UTF-8     | fr_FR.UTF-8  |        |               |
16453|pg-gvm|10|2200|f|22.6||
        OK: At least one user exists.
Step 6: Checking Greenbone Security Assistant (GSA) ...
        OK: Greenbone Security Assistant is present in version Deamon 24.12.2~git.
Step 7: Checking if GVM services are up and running ...
        OK: gvmd service is active.
        OK: gsad service is active.
Step 8: Checking few other requirements...
        OK: nmap is present.
        OK: ssh-keygen found, LSC credential generation for GNU/Linux targets is likely to work.
        OK: nsis found, LSC credential package generation for Microsoft Windows targets is likely to work.
        OK: xsltproc found.
        WARNING: Your password policy is empty.
        SUGGEST: Edit the /etc/gvm/pwpolicy.conf file to set a password policy.
Step 9: Checking greenbone-security-assistant...
        OK: greenbone-security-assistant is installed

It seems like your GVM-25.04.0 installation is OK.
```

Mot de passe perdu ?

Si vous avez perdu le mot de passe admin généré par gvm-setup, vous pouvez le réinitialiser avec : *sudo runuser -u _gvm -- gvmd --user=admin --new- password=VotreNouveauMotDePasse*

Apres avoir fait la vérification de l'installation, on peut procéder au lancement de l'outil avec la commande ***sudo gvm-start.***

```
┌──(jean㉿lezelote)-[~]
└─$ sudo gvm-start
[>] Please wait for the GVM services to start.
[>]
[>] You might need to refresh your browser once it opens.
[>]
[>]  Web UI (Greenbone Security Assistant): https://127.0.0.1:9392

● gsad.service - Greenbone Security Assistant daemon (gsad)
     Loaded: loaded (/usr/lib/systemd/system/gsad.service; disabled; preset: disabled)
     Active: active (running) since Tue 2026-01-27 08:27:04 GMT; 16ms ago
 Invocation: 2d549a17e76a4b998647aad3393154dd
       Docs: man:gsad(8)
             https://www.greenbone.net
   Main PID: 1728 (gsad)
      Tasks: 3 (limit: 9244)
     Memory: 3.8M (peak: 3.8M)
        CPU: 21ms
     CGroup: /system.slice/gsad.service
             ├─1728 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392
             └─1733 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392

janv. 27 08:27:03 lezelote systemd[1]: Starting gsad.service - Greenbone Security Assistant daemon (gsad)...
janv. 27 08:27:04 lezelote systemd[1]: Started gsad.service - Greenbone Security Assistant daemon (gsad).
janv. 27 08:27:04 lezelote gsad[1728]: gsad main:MESSAGE:2026-01-27 08h27.04 utc:1728: Starting GSAD version 24.12.2~git
```

Problème : Services ne démarrent pas
Solution : Vérifiez les logs avec ***sudo journalctl -u gvmd - u ospd-openvas -u gsad***. Souvent causé par un manque de RAM. Essayez de redémarrer tous les services : ***sudo gvm-stop && sudo gvm-start***

Problème : Interface web inaccessible
Solution : Vérifiez que gsad est bien démarré : ***sudo systemctl status gsad***. Par défaut, l'interface est accessible sur *https://127.0.0.1:9392*. Acceptez le certificat auto-signé dans votre navigateur.

4) Configuration après l'installation

a) Synchronisation des flux

OpenVAS nécessite trois types de flux pour fonctionner correctement. Le flux NVT (Network Vulnerability Tests) contient plus de 50 000 contrôles de sécurité. Le flux SCAP (Security Content Automation Protocol) comprend les définitions CVE et les données CPE pour l'identification des vulnérabilités. Le flux CERT fournit des avis de sécurité provenant de diverses équipes d'intervention en cas d'urgence informatique. La synchronisation initiale peut prendre entre 1 et 3 heures.

```
# Sync all feeds
sudo greenbone-feed-sync --type GVMD_DATA
sudo greenbone-feed-sync --type SCAP
sudo greenbone-feed-sync --type CERT
```

b) Vérification du service

Vérifiez que tous les composants GVM fonctionnent correctement. Les services clés comprennent gvmd (gestionnaire), gsad (interface Web), ospd-openvas (enveloppe du scanner) et notus-scanner (détection des produits). Vérifiez l'état des services et les ports d'écoute.

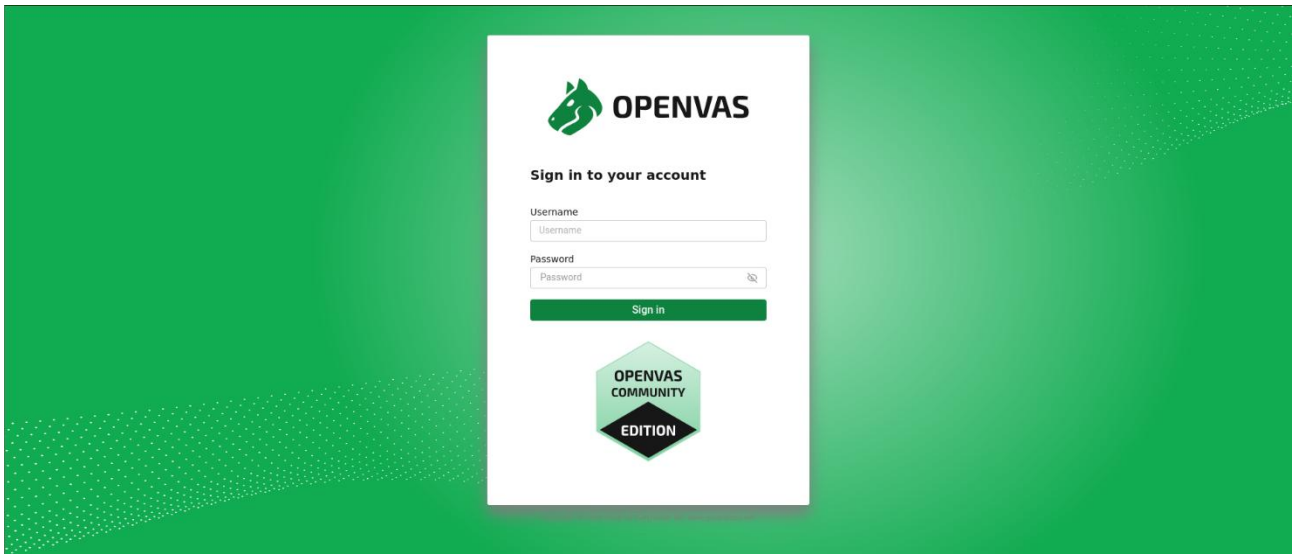
```
# Check service status
sudo systemctl status gvmd gsad ospd-openvas
# Verify listening ports
sudo ss -tulpn | grep -E '(9390|9392|80|443)'
# Run comprehensive check
sudo gvm-check-setup
```

c) Configuration utilisateur administrateur

Créez des utilisateurs supplémentaires ou réinitialisez le mot de passe administrateur si nécessaire. La gestion des utilisateurs comprend la définition des rôles (administrateur, utilisateur, observateur) et des autorisations d'accès. La gestion sécurisée des identifiants est essentielle pour les environnements de production.

```
# Create new user
sudo gvmd --create-user=username --password=password
# Reset admin password
sudo gvmd --user=admin --new-password=newpassword
# List all users
sudo gvmd --get-users
```

Une fois l'installation terminée et tous les services vérifiés, vous êtes prêt à accéder à l'interface web. Ouvrez votre navigateur et rendez-vous à l'adresse ***https://127.0.0.1:9392***. Connectez-vous avec l'utilisateur admin et le mot de passe généré lors du *gvm-setup*.



Si vous souhaitez accéder à l'interface depuis une autre machine du réseau, vous devrez configurer gsad pour écouter sur toutes les interfaces avec ***sudo gsad --listen=0.0.0.0 --port=9392***, mais attention aux implications de sécurité.

D. Configuration Initiale et Premier Contact

Après votre première connexion à l'interface Greenbone Security Assistant (GSA), vous découvrez un tableau de bord complet qui peut sembler intimidant au premier abord. Cette section vous guide dans la configuration initiale essentielle pour une utilisation optimale d'OpenVAS.

1) Navigation dans l'Interface GSA

L'interface GSA est organisée en plusieurs sections principales accessibles via le menu latéral gauche :

- Dashboard : Vue d'ensemble avec statistiques et graphiques des derniers scans
- Scans : Gestion des tâches (Tasks) et des résultats
- Assets : Inventaire des systèmes découverts et leurs vulnérabilités

- Configuration : Cibles (Targets), scanners, credentials
- Administration : Gestion des utilisateurs, feeds, paramètres système

2) Gestion des Utilisateurs

Par défaut, vous êtes connecté avec l'utilisateur admin qui dispose de tous les privilèges. Pour une utilisation en équipe, créez des utilisateurs supplémentaires avec des rôles appropriés.

Créer un utilisateur : Administration → Users → Nouvelle icône → Remplir le formulaire avec nom, mot de passe et rôle (Admin, User, Observer, etc.).

Mise à Jour Automatique des Feeds

Par défaut, GVM synchronise les feeds une fois par jour. Pour vérifier la dernière mise à jour : Administration → Feed Status. Vous y verrez la date de dernière synchronisation pour NVT, SCAP et CERT. Des feeds à jour sont essentiels pour détecter les vulnérabilités récentes.

Configuration du Scanner

OpenVAS est configuré par défaut avec un scanner local. Vérifiez sa disponibilité : Configuration → Scanners. Le scanner "OpenVAS Default" doit apparaître avec un statut vert. Ici, vous pouvez aussi ajuster les paramètres de performance comme le nombre de tests simultanés.

Paramètres de Performance

Pour optimiser les performances selon votre matériel : Configuration → Scan Configs → Créez une copie de "Full and fast" → Ajustez "Max concurrent NVTs" (4-8 pour 4-8 GB RAM) et "Max concurrent hosts" (3-5 selon bande passante). Ces réglages évitent la surcharge système.

Une configuration de sécurité importante consiste à changer le mot de passe admin par défaut si ce n'est pas déjà fait, activer les logs détaillés pour l'audit, et configurer des sauvegardes régulières de la base PostgreSQL avec pg_dump gvmd > backup.sql. Si vous prévoyez d'exposer l'interface sur le réseau, configurez obligatoirement un certificat SSL valide et envisagez l'utilisation d'un reverse

proxy avec authentification supplémentaire.

E. Votre Premier Scan Pas à Pas

Le moment est venu de lancer votre tout premier scan de vulnérabilités avec OpenVAS. Ce tutoriel détaillé vous accompagne à travers chaque étape, depuis la définition de la cible jusqu'à l'analyse des résultats. Pour cet exemple pratique, nous allons scanner une machine de test Metasploitable ou une VM Linux locale.

Création d'une Cible (Target)

Dans le menu Configuration ³ Targets ³ Cliquez sur l'icône "Nouvelle cible". Donnez un nom descriptif comme "Test - VM Ubuntu Local". Dans le champ "Hosts", saisissez l'adresse IP de votre cible (ex : 192.168.1.100) ou une plage (192.168.1.0/24). Sélectionnez "Scan all TCP ports" pour l'instant. Cliquez sur "Save".

Choix de la Configuration de Scan

Retournez au menu Scans ³ Tasks ³ Nouvelle tâche. Donnez un nom comme "Premier scan Ubuntu". Dans "Scan Targets", sélectionnez la cible créée précédemment. Pour "Scan Config", choisissez "Full and fast" qui offre un bon compromis entre exhaustivité et rapidité (environ 30-60 min pour un serveur standard).

Lancement du Scan

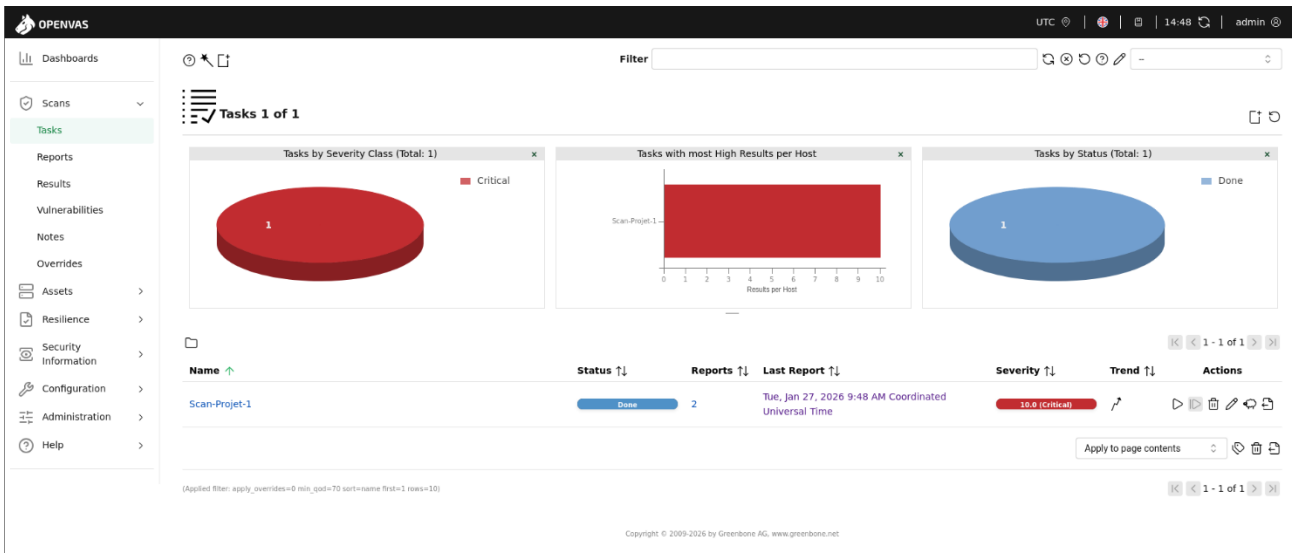
Dans la liste des tâches, cliquez sur l'icône "Play" (triangle vert) à côté de votre tâche. Le statut passe immédiatement à "Running" avec une barre de progression. OpenVAS commence par une phase de découverte (détection des ports ouverts), puis lance les tests de vulnérabilités sur chaque service détecté.

Suivi en Temps Réel

Cliquez sur le nom de la tâche pour voir les détails en temps réel. Un graphique circulaire montre la répartition des vulnérabilités par niveau de sévérité au fur et à mesure de leur détection. Le champ "Progress" indique le pourcentage d'avancement. Vous pouvez voir les hôtes scannés et les vulnérabilités détectées s'accumuler.

Fin du Scan et Accès au Rapport

Une fois terminé (statut "Done"), cliquez sur le rapport (icône document). Vous accédez à une vue détaillée classant les vulnérabilités par sévérité : High (rouge), Medium (orange), Low (bleu), Log (gris). Chaque entrée affiche le nom de la vulnérabilité, le CVE associé, le port concerné et un résumé



Astuce pour votre premier scan : Commencez par scanner une seule machine de test (VM ou environnement isolé) plutôt qu'un réseau entier. Cela vous permet de vous familiariser avec l'interface sans risquer de surcharger le système ou d'impacter la production. Attendez- vous à un scan d'environ 30-60 minutes pour un serveur standard avec "Full and fast".

Que Faire si le Scan Reste Bloqué ?

Si votre scan ne progresse pas après 10-15 minutes ou reste à 0%, vérifiez d'abord que la cible est accessible (ping). Consultez les logs système avec ***sudo tail -f /var/log/gvm/gvmd.log***. Un scan peut se bloquer si le scanner est surchargé ou si la cible filtre agressivement les requêtes (pare-feu, IDS/IPS).

Le Scan est Très Lent

La vitesse dépend de nombreux facteurs : nombre de ports ouverts, réactivité de la cible, configuration de scan choisie. "Full and fast" teste environ 50 000 NVT. Pour accélérer, utilisez "Quick" (moins exhaustif) ou créez une config personnalisée limitant le nombre de tests simultanés si votre RAM est limitée.

F. Comprendre et Interpréter les Résultats

Savoir lire et interpréter correctement un rapport OpenVAS est une compétence cruciale. Un rapport brut peut contenir des centaines de résultats, et tous ne représentent pas le même niveau de risque. Cette section vous apprend à trier l'essentiel de l'accessoire et à prioriser vos actions de remédiation.

Le score CVSS (Common Vulnerability Scoring System) est calculé selon plusieurs vecteurs : complexité d'exploitation, privilèges requis, interaction utilisateur nécessaire, et impact sur la confidentialité/intégrité/disponibilité. Un score élevé ne signifie pas automatiquement un risque critique dans VOTRE contexte. Par exemple, une vulnérabilité de serveur web notée 9.8 sur un serveur interne sans accès Internet peut être moins prioritaire qu'une faille de score 7.5 sur votre serveur web public.

Critical

Score CVSS 9.0-10.0. Vulnérabilités critiques exploitables à distance sans authentification urgente impérative dans les 24-48h. Correction.

High

Score CVSS 7.0-8.9. Vulnérabilités graves pouvant mener à une compromission système. Correction prioritaire dans la semaine.

Medium

Score CVSS 4.0-6.9. Risques modérés nécessitant attention. Planifier correction dans les 30 jours selon contexte.

Low

Score CVSS 0.1-3.9. Risques mineurs, souvent informationnels. Traiter lors des maintenances régulières.

1) Anatomie d'un Résultat de Vulnérabilité

Chaque vulnérabilité détectée contient plusieurs informations essentielles :

- Nom : Description courte du problème (ex: "Apache HTTP Server Version Détection")
- CVE : Identifiant unique (ex: CVE-2021-44228 pour Log4Shell)
- CVSS Score : Note de 0 à 10 indiquant la sévérité
- Port/Service : Où la vulnérabilité a été trouvée (ex: 443/tcp/https)
- Description : Explication technique détaillée
- Solution : Recommandations de correction
- Références : Liens vers CVE, exploits publics, bulletins de sécurité

Vulnerability		Severity	QoD	Host IP	Host Name	Location	EPSS Score	EPSS Percentile	Created
Possible Backdoor: Ingreslock		10.0 (Critical)	99 %	192.168.10.74	192.168.10.74	1524/tcp	N/A	N/A	Tue, Jan 27, 2026 10:14 AM Coordinated Universal Time

Summary

A backdoor is installed on the remote host.

Detection Result

The service is answering to an 'id;' command with the following response: uid=0(root) gid=0(root)

Detection Method

Details: Possible Backdoor: Ingreslock OID: 1.3.6.1.4.1.25623.1.0.103549

Version used: 2023-07-25T05:05:58Z

Impact

Attackers can exploit this issue to execute arbitrary commands in the context of the application. Successful attacks will compromise the affected isystem.

Solution

Solution Type: Workaround
A whole cleanup of the infected system is recommended.

Faux Positifs

OpenVAS, comme tout scanner automatisé, génère des faux positifs (vulnérabilités signalées mais non réelles). Exemples typiques : détection de version obsolète alors que des correctifs sont back portés, alertes sur des services désactivés. Validation manuelle indispensable avant toute remédiation, surtout pour les résultats High/Critical.

Faux Négatifs

L'inverse existe aussi : vulnérabilités réelles non détectées. Raisons courantes : scan non authentifié manquant des problèmes internes, configuration de scan trop rapide, service protégé par WAF/IPS. OpenVAS ne remplace jamais un audit manuel approfondi, il le complète

Ne corrigez pas aveuglément par ordre de CVSS. Considérez : exposition (Internet vs. interne), criticité métier du système, exploitabilité réelle (exploit public disponible ?), données hébergées. Créez une matrice risque = sévérité × exposition × criticité.

Priorisation Intelligente

Pour filtrer efficacement les résultats dans l'interface GSA, utilisez les options de filtrage avancé : cliquez sur l'icône filtre, puis filtrez par sévérité (ex: "severity>7.0" pour n'afficher que High et Critical), par hôte spécifique, par famille de NVT, ou par présence de CVE. Vous pouvez aussi exporter uniquement les vulnérabilités filtrées pour un rapport ciblé. Les résultats marqués "Log" (gris) sont purement informationnels (détection de version, identification de service) et ne représentent généralement pas de risque direct, mais peuvent révéler des informations utiles pour un attaquant (empreinte digitale du système).

G. Cas d'Usage Pratiques et Scans Avancés

Maintenant que vous maîtrisez les bases, explorons des scénarios d'utilisation réels qui couvrent différents types d'infrastructures et de contextes. Ces exemples vous préparent à des situations professionnelles concrètes.

❖ Scan Authentifié SSH d'un Serveur Linux

Les scans authentifiés fournissent une vue beaucoup plus précise en permettant à OpenVAS de vérifier les paquets installés et leur version. Configuration → Credentials → New Credential → Type: Username + Password → Saisissez vos identifiants SSH. Puis dans votre Target, ajoutez ces credentials dans "Credentials for authenticated checks". Le scan détectera les CVE affectant les packages installés même si les ports ne révèlent rien.

❖ Audit de Serveur Web (Apache/Nginx)

Créez une cible avec l'IP du serveur web et les ports 80,443. Utilisez la config "Full and fast". OpenVAS testera : vulnérabilités applicatives (XSS, SQLi dans les apps communes), configuration SSL/TLS (protocoles faibles, certificats), version des serveurs web et leurs CVE, headers de sécurité manquants (CSP, HSTS).

Attention aux faux positifs

sur les headers car leur absence n'est pas toujours critique.

❖ Scan de Réseau Local Complet

Pour scanner tout un réseau (ex: 192.168.1.0/24), créez une Target avec cette plage.

Utilisez "Discovery" scan config d'abord pour cartographier les hôtes vivants et leurs services. Puis lancez un "Full and fast" uniquement sur les IP critiques identifiées. Scanner 254 IP avec Full peut prendre 12-24h et générer énormément de données.

Planifiez ces scans la nuit ou le weekend.

H. Reporting, Légalité et Optimisation

La dernière étape d'un scan de vulnérabilités est la production d'un rapport exploitable et sa présentation aux parties prenantes. Parallèlement, il est crucial de comprendre le cadre légal et d'optimiser vos scans pour une efficacité maximale.

1) Types de Rapports et Export

OpenVAS offre plusieurs formats de rapports adaptés à différents publics :

- PDF : Rapport formaté pour direction/clients non techniques. Inclut graphiques et résumé exécutif.
- HTML : Rapport interactif avec navigation facilitée, idéal pour partage interne équipe IT.
- XML : Format structuré pour import dans SIEM, GRC ou autres outils d'analyse. CSV : Export des vulnérabilités en tableur pour traitement Excel/LibreOffice. TXT : Format texte simple pour archivage ou traitement en ligne de commande.

Pour exporter : Ouvrez le rapport → Icône de téléchargement → Choisissez format et filtres éventuels → Download.

1

Cadre Légal du Scanning

Scanner un système sans autorisation explicite est illégal dans la plupart des pays (France, USA, UE). Obtenez TOUJOURS une autorisation écrite avant tout scan. Cette autorisation doit spécifier : périmètre exact (IP/domaines), dates et heures autorisées, types de tests permis, contact en cas d'incident. Conservez ces documents minimum 5 ans.

2

Responsabilité et Éthique

En tant qu'opérateur de scan, vous être responsable des impacts : interruption de service (DoS), déclenchement d'alertes, perturbation des systèmes industriels sensibles. Informez toujours les équipes IT avant un scan. En cas de découverte de vulnérabilité critique, suivez un processus de divulgation responsable : notifiez le propriétaire, donnez un délai de correction raisonnable (90 jours standard).

3

Sécurisation de la Plateforme OpenVAS

Votre scanner OpenVAS est une cible de choix : il contient l'inventaire complet de vos failles ! Mesures essentielles : accès HTTPS uniquement avec certificat valide, authentification forte (2FA si possible), isolation réseau (VLAN dédié), mises à jour régulières, sauvegardes chiffrées, logs d'audit activés, accès limité aux administrateurs sécurité uniquement.

Optimisation Performance

Pour améliorer vitesse de scan : augmentez "Max concurrent NVTs" si vous avez la RAM, utilisez "Alive Test" ICMP plutôt que "Consider Alive", désactivez les familles NVT non pertinentes (ex: Windows sur serveurs Linux), planifiez scans en heures creuses pour réduire timeouts réseau.

Scans Programmés

Pour automatisation : Scans ³ Tasks ³ Éditer tâche ³ Onglet "Schedule" ³ New Schedule ³ Définissez récurrence (daily, weekly, monthly) et timezone. Combinez avec alertes email automatiques sur nouvelles vulnérabilités High/Critical pour monitoring continu.

OpenVAS vs Nessus

Nessus (Tenable) offre performances supérieures, meilleure détection, support commercial, mais coûte 3000-5000¬/an. OpenVAS gratuit convient parfaitement PME, labs, audits ponctuels. Pour grandes entreprises avec milliers d'assets, Nessus recommandé. OpenVAS excellent choix pour démarrer en cybersécurité.

Ressources pour aller plus loin : Documentation officielle Greenbone (https://docs.greenbone.net), communauté forum Greenbone, CVE Database (cve.mitre.org) pour comprendre les vulnérabilités, OWASP Testing Guide pour tester au-delà des scans automatisés, cours certifiants (CEH, OSCP) incluant modules gestion vulnérabilités. Pratiquez

Félicitations ! Vous avez maintenant toutes les clés pour utiliser OpenVAS efficacement, depuis l'installation jusqu'à la production de rapports professionnels. La maîtrise vient avec la pratique : scannez régulièrement, analysez en profondeur, validez manuellement, et surtout, ne cessez jamais d'apprendre. La cybersécurité évolue constamment, et votre veille doit être permanente. Bonne chasse aux vulnérabilités !

sur environnements légaux : Metasploitable, DVWA, VulnHub VMs, TryHackMe labs.